



Detection Engineering for Data Loss Prevention

Designing Splunk-Based Alerts and Response Plans
for Data Exfiltration Incidents

Master of Computer Science · Final Project Presentation

4

Detection Use Cases

Presentation Agenda

01

Project Motivation & Problem Statement

02

System Design & Architecture

03

Detection Use Cases & SPL Implementation

04

Evaluation Results

05

Lessons Learned & Limitations

06

Future Work & Conclusion

The Data Exfiltration Challenge



Data leaves via many channels

Web uploads, cloud storage, email, DNS, and collaboration tools — all exploitable.

DLP tools operate in silos

Single-channel inspection creates fragmented visibility and alert fatigue.

SIEM data underutilised

Aggregated telemetry in Splunk is rarely used for DLP-specific detection.

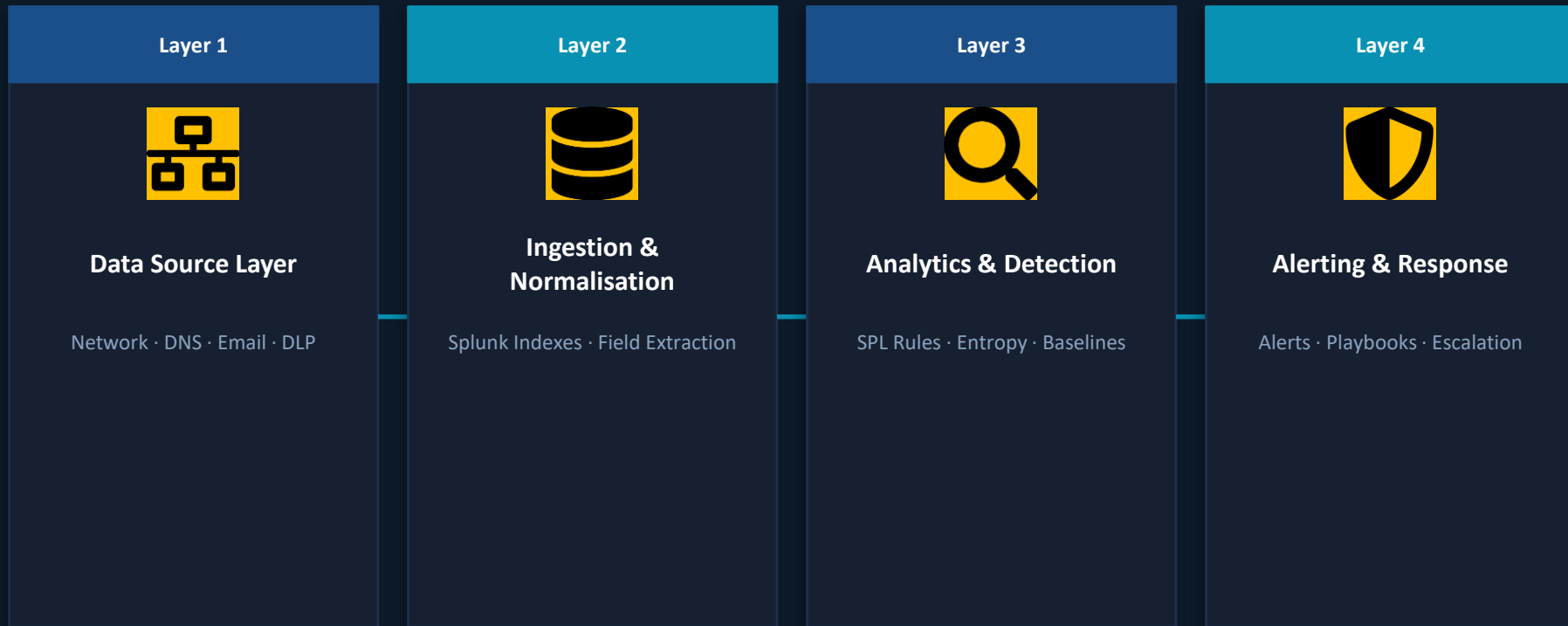
No structured response

Few organisations have playbooks coupling alert generation to SOC action.

How This Project Addresses It

- Structured detection-engineering methodology applied inside Splunk
- Cross-channel correlation across network, DNS, email, and DLP logs
- Four high-fidelity detection use cases with tuned SPL rules
- Coupled incident response playbooks for each detection scenario
- Evaluated on 33,000+ synthetic events — 100% recall, 94% precision

Four-Layer System Architecture



Data flows top-to-bottom through each layer: raw logs → normalised events → detected alerts → analyst action

Data Sources & Normalised Fields



Network / Proxy

index = dlp_test

src_ip · dest_ip · domain · bytes · user

UC1, UC2



DNS Query Logs

index = dns_logs

src_ip · query_name · query_type · response

UC3



Email Audit Logs

index = email_logs

user · recipient · action · attachment_size

UC4



DLP Policy Logs

index = dlp_policy

user · host · policy_name · action · severity

Enrich all

Four Detection Use Cases

UC1



High-Volume Outbound Transfer

Primary signal:

> 500 MB / host / domain / hr

→ *Playbook PB1*

UC2



Unsanctioned Cloud Storage

Primary signal:

Domain in unsanctioned list

→ *Playbook PB2*

UC3



DNS-Based Exfiltration

Primary signal:

Volume + Length + Entropy

→ *Playbook PB3*

UC4



Email-Based Exfiltration

Primary signal:

> 50 sends OR > 100 MB attach

→ *Playbook PB4*

UC1 & UC2 — Volume & Unsanctioned Domain Detection

UC1 — High-Volume Outbound Transfer

```
index=dlp_test
| stats sum(bytes) as total_bytes
  count as event_count by src_ip domain user
| where total_bytes > `outbound_bytes_threshold`
| eval total_gb = round(total_bytes/1073741824,2)
| lookup asset_inventory src_ip
  OUTPUT hostname department criticality
| sort - total_gb
```

UC1 Result: 4 / 4 TP · 0 FP · Precision 100% · Recall 100%

UC2 — Unsanctioned Domain

```
index=dlp_test
| lookup unsanctioned_domains.csv
  domain OUTPUT domain as flagged
| lookup sanctioned_services.csv
  user domain OUTPUT user as exempt
| where isnotnull(flagged)
  AND isnull(exempt)
| stats sum(bytes) as total_bytes
  count by src_ip domain user
```

UC2 Result: 6 / 6 TP · 0 FP · Precision 100% · Recall 100%



Correlation: UC1 + UC2 fired simultaneously on 2 of 4 UC1 scenarios — large transfers to unsanctioned domains. This compound signal escalates severity from High to Critical.

UC3 — DNS-Based Exfiltration with Entropy Scoring

Why Three Signals?

- ▶ **Query Volume alone:** Monitoring agents also generate high query counts — FP risk.
- ▶ **Subdomain Length alone:** Long hostnames exist in legitimate CDN and monitoring traffic.
- ▶ **Entropy alone:** Not all high-entropy strings are tunneled data.
- ▶ **All three combined:** Uniquely identifies base64-encoded payload traffic. Zero FP after tuning.

UC3 — DNS Exfiltration (Simplified)

```
index=dns_logs
| eval subdomain=mvindex(split(query_name,"."),0)
| eval sub_len=len(subdomain)
| eval entropy=`calc_entropy(subdomain)`
| stats count as query_count
      avg(sub_len) as avg_len
      avg(entropy) as avg_entropy by src_ip
| where query_count > `dns_query_count_threshold`
      AND avg_len > `dns_subdomain_len_threshold`
      AND avg_entropy > `dns_entropy_threshold`
```

Entropy Tuning Results

Host	Queries/hr	Avg Entropy	Assessment
10.0.0.14	1,842	4.21	✓ Confirmed Tunnel
10.0.0.31	987	4.08	✓ Confirmed Tunnel
10.0.0.7	412	2.87	X Cleared — Monitoring

UC4 — Email-Based Exfiltration (Dual-Rule)

Rule A — Mass External Forwarding

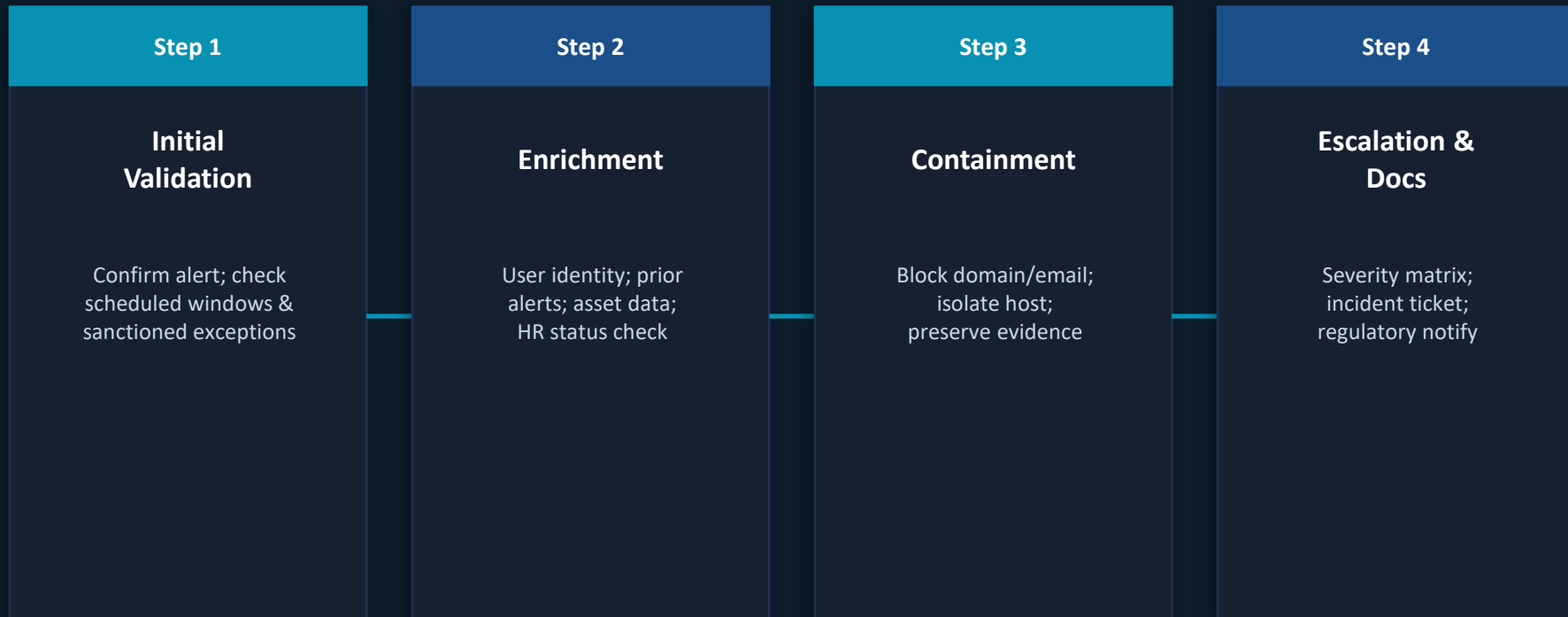
```
index=email_logs (action=send OR action=forward)
| where NOT match(recipient,"@company\.com$")
| lookup authorized_senders.csv user
  OUTPUT user as exempt_user
| where isnull(exempt_user)
| stats count as external_sends
  dc(recipient) as unique_recipients by user
| where external_sends > `email_send_threshold`
  OR unique_recipients > `email_recipient_threshold`
```

Rule B — Bulk Attachment Volume

```
index=email_logs action=send attachment_size>0
| where NOT match(recipient,"@company\.com$")
| lookup authorized_senders.csv user
  OUTPUT user as exempt_user
| where isnull(exempt_user)
| stats sum(attachment_size) as total_bytes
  count as email_count by user
| where total_bytes > `email_attach_bytes_threshold`
| eval total_mb=round(total_bytes/1048576,1)
```

User	Rule	Ext. Sends / Attach. Vol	Assessment
bob	A	147 sends · 89 recipients	✓ Mass Forwarding
carol	B	23 emails · 312 MB	✓ Bulk Attachment
dave	A	61 sends · 12 recipients	✓ Mass Forwarding
frank	A	62 sends (campaign)	FP → Added to exceptions

Incident Response Playbooks — Structure



Escalation triggers: Sensitive data confirmed → CISO + Legal (1 hr) · DNS tunnel (any) → IR team (Immediate) · Insider threat → CISO + HR + Legal (Immediate)

Test Suite Overview

23

Test Cases Executed

5

E2E Scenarios

33K+

Synthetic Events

100%

Detection Recall

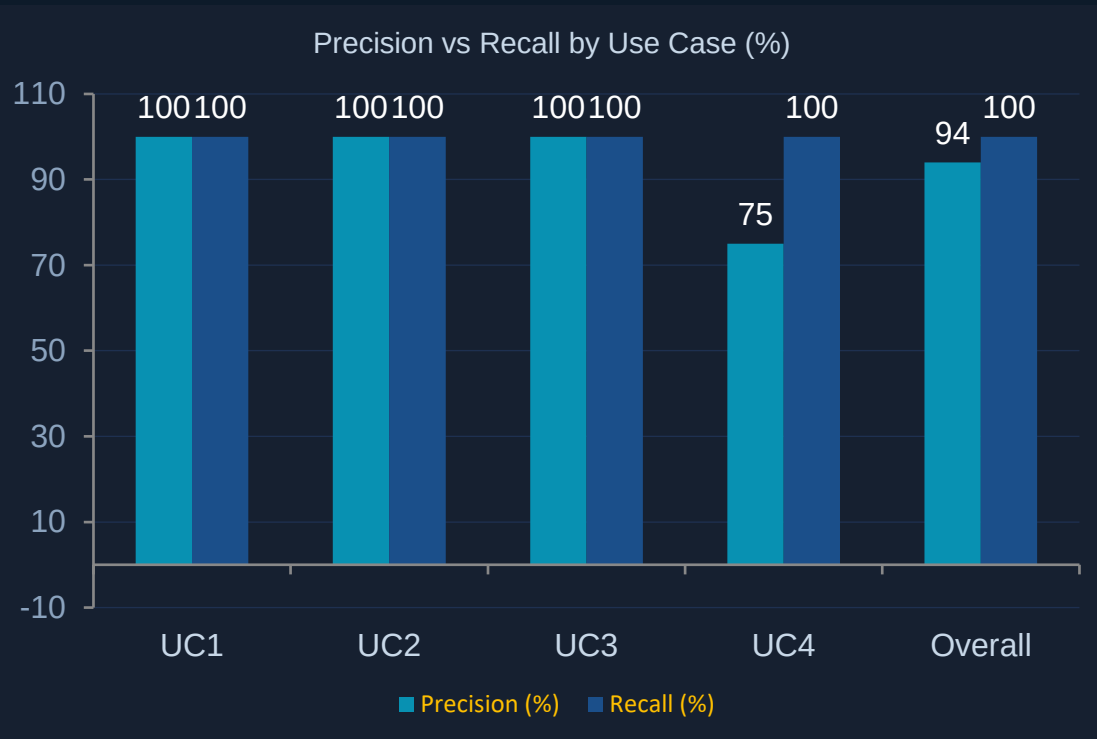
Test Type Breakdown

Test Type	Tests Run	Pass	Managed FP
Unit-Level Detection	14	14	0
Scenario-Based (E2E)	5	5	0
Baseline / False-Positive	4	3	1
Performance Benchmarks	4	4	0

Datasets Used

- Synthetic dataset: ~24,000 events
- Benign validation: ~8,000 events
- 4 source types: proxy, DNS, email, DLP
- Embedded exfiltration + benign mix

Detection Performance — Precision, Recall & F1



Use Case	TP	FP	FN	F1
UC1 – High-Volume	4	0	0	1.00
UC2 – Unsanctioned	6	0	0	1.00
UC3 – DNS Exfil	2	0	0	1.00
UC4 – Email Exfil	3	1	0	0.86
OVERALL	15	1	0	0.97



UC4 FP: Legitimate bulk email campaign — user added to authorized_senders.csv after test.

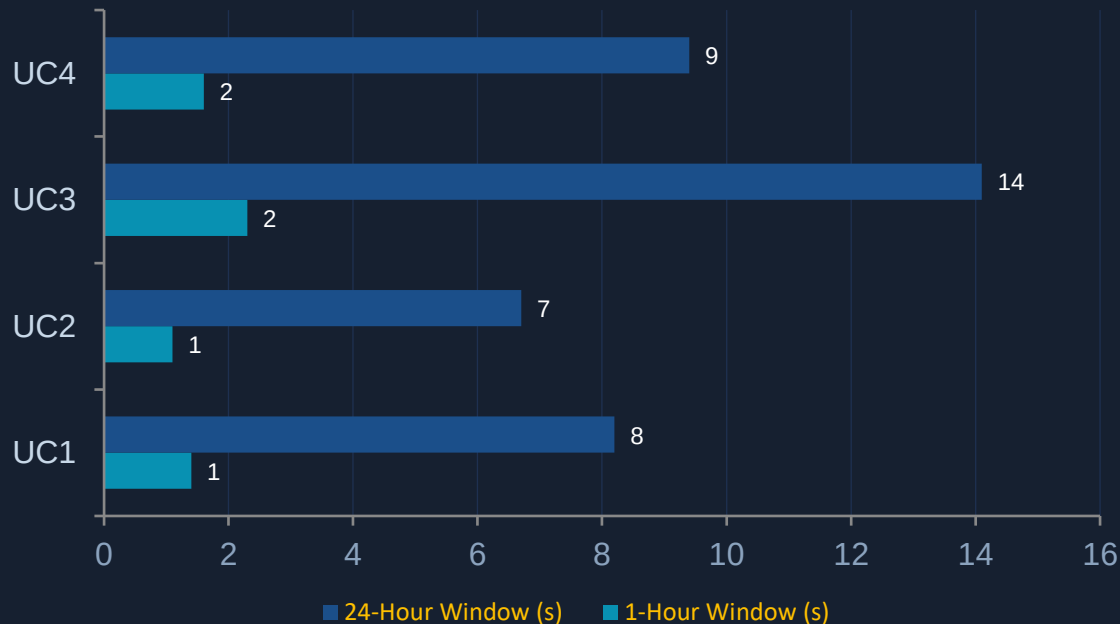
End-to-End Scenario Test Results

S1	Insider uploads archive to Dropbox	Rules: UC1 + UC2	Playbook	PASS
S2	Employee bulk-forwards pre-resignation	Rules: UC4 (Rule A)	Playbook	PASS
S3	Compromised host runs DNS tunnel	Rules: UC3	Playbook	PASS
S4	Staged file sync to WeTransfer	Rules: UC1 + UC2	Playbook	PASS
S5	Mass attachment send to Gmail	Rules: UC4 (Rule B)	Playbook	PASS

5 / 5 scenarios passed • 100% detection coverage • 100% correct playbook routing

Query Performance Benchmarks

Query Execution Time by Use Case



SLA Target

All searches must complete within 30 seconds for a 24-hour look-back window.



All 4 rules met SLA

UC3 note:

Entropy computation adds ~0.9 s overhead. For >1M DNS events/day, pre-compute at index time to reduce 24-hr window to ~4–5 s.

Key Lessons Learned



Multi-signal beats single-signal

UC3 showed that query volume, subdomain length, and entropy together uniquely identify tunneling. No single signal was sufficient — each produced FPs or blind spots independently.



Exception lookups need operational ownership

The UC4 FP (marketing bulk campaign) was predictable. Exception CSVs must have a named owner and quarterly review cadence — they're ongoing commitments, not one-time setup.



Severity banding improves analyst speed

Adding Critical / High / Medium / Low tiers to UC1 based on transfer volume significantly reduced analyst triage time. Flat severity forces re-examination of raw data for every alert.



Version control for SPL is underrated

Git diffs on SPL rules made every tuning decision auditable and reversible. On two occasions, comparing before/after versions saved significant debugging time.

Known Limitations

Synthetic data dependency

All testing used purpose-built datasets. Real enterprise traffic will have more diversity, noise, and edge cases. FP rates in production may be higher until exception lookups are populated from observed baselines.

Static thresholds

Current rules use fixed thresholds. Seasonal patterns (year-end reporting, product launches) may trigger elevated FPs during peak activity. Dynamic baselines (rolling percentiles via MLTK) would address this.

No SOAR integration

Playbooks are currently semi-manual. Without automation, response consistency depends on analyst availability and discipline under high alert load.

Exfiltration-phase coverage only

The framework detects exfiltration-phase activity. It does not correlate with credential compromise, lateral movement, or privilege escalation — earlier attack lifecycle stages that would provide even earlier warning.

Single-organisation scope

Thresholds are calibrated for the synthetic dataset's implied organisational profile. Production deployment requires recalibration against the target organisation's actual traffic baselines.

Future Work — Prioritised Roadmap

P1



SOAR Integration

Automate domain block, account suspension, legal hold initiation

P2



Dynamic Baselines (MLTK)

Per-entity rolling thresholds via Splunk ML Toolkit

P3



ML Risk Scoring Layer

Aggregate multi-UC signals into a composite exfiltration risk score per user

P4



Additional Vectors

USB · Printer · Teams/Slack · HTTPS tunneling ports

P5



Production Data Validation

30-day monitor-only mode; recalibrate thresholds against real baseline

Project Deliverable Package



SPL Detections

- uc1–uc4_*.spl (4 rules)
- calc_entropy.spl (macro)
- thresholds.conf (all macros)



Lookup Tables

- unsanctioned_domains.csv
- authorized_senders.csv
- sanctioned_services.csv
- asset_inventory.csv



IR Playbooks

- playbook_pb1.md – PB4.md
- Full 4-step each use case
- SPL enrichment queries embedded



Test Datasets

- synthetic_dataset/ ~24K events
- benign_dataset/ ~8K events
- 4 source types covered



Evaluation

- test_catalog.xlsx (4 sheets)
- tuning_log.md (7 entries)
- eval_results.md (full results)



Final Report

- final_report.docx
- Complete project documentation
- Lessons learned & future work

Project Scorecard — Requirements Met

FR1	Data Ingestion (4 source types)	✓	NFR	Performance: all queries < 30 s (24-hr window)	✓
FR2	4 Detection Use Cases implemented	✓	NFR	Explainability: thresholds fully documented	✓
FR3	SPL correlation logic with contextual alerts	✓	NFR	Maintainability: Git repo; macros; CSVs	✓
FR4	4 Incident Response Playbooks finalised	✓	NFR	Privacy: synthetic data only; no PII	✓
FR5	Evaluation on synthetic + benign datasets	✓			

All functional and non-functional requirements met · Project completed on schedule · Zero timeline deviations



Thank You

Detection Engineering for Data Loss Prevention

4

Detection
Use Cases

100%

Recall

94%

Precision

20

Artefacts
Delivered